ООО «Проектные системы»

УТВЕРЖДЕН
АПС.АЛЬФА.001.ПС.2-ЛУ

АВТОМАТИЗИРОВАННАЯ СИСТЕМА «АЛЬФА»

версия 1.0.0

РЕГЛАМЕНТ УПРАВЛЕНИЯ УЧЕТНЫМИ ЗАПИСЯМИ И ПРАВАМИ ДОСТУПА АС «АЛЬФА»

АПС.АЛЬФА.001.И7.2

Листов: 8

2026

АС «АЛЬФА» версии 1.0.0 – вымышленная веб-система регистрации и обработки внутренних обращений. Заказчик – условное АО «Северный контур», Исполнитель – условное ООО «Проектные системы». Данные, адреса и процедуры являются проектными примерами; наличие работающего программного продукта и факт испытаний не утверждаются.

Подп. и дата | Инв. № дубл. | Взам. инв. № | Подп. и дата | Инв. № подл.

Сведения об авторе

Автор демонстрационного документа – Александр Сибиряков, аналитик и технический писатель.

Документ подготовлен специально для профессионального портфолио и демонстрации навыков анализа требований, проектирования и документирования информационных систем. АС «Альфа», организации, данные и проектные ситуации являются условными.

Профессиональный профиль, другие образцы работ и контакты для предложений о сотрудничестве и трудоустройстве:

https://alsibir.github.io/alsibir-expert/

Аннотация

Документ определяет согласование, выдачу, изменение, отзыв и пересмотр доступа. Относится к проектной АС «Альфа» версии 1.0.0. Все примеры синтетические; фактические испытания не проводились.

Содержание

Назначение регламента	4
Роли пользователей	4
Матрица полномочий	4
Создание учетной записи	5
Изменение роли и атрибутов	5
Блокирование и разблокирование	5
Удаление и архивирование	6
Требования к аутентификации	6
Периодический пересмотр прав	6
Привилегированные действия	7
Аудит событий доступа	7
Действия при компрометации учетной записи	7

Назначение регламента

Регламент устанавливает выдачу, пересмотр и отзыв доступа; требования ADM-001 и SEC-001.

Роли пользователей

Пользователь работает со своими заявками; Оператор – со всеми заявками; Администратор управляет учётными записями и конфигурацией, но не получает доступ к содержанию заявок; Аудитор читает журнал аудита без доступа к вложениям. Каждая запись имеет ровно одну роль. Совмещение выполняется отдельными учётными записями.

Матрица полномочий

Матрица ниже применяется и к UI, и к API. Отсутствие разрешения означает запрет. Администратор не вправе назначать себе роль Оператора без отдельного согласования.

Данные приведены в таблице 1.

Таблица 1 – Матрица полномочий

Операция	Пользователь	Оператор	Администратор	Аудитор
Создать заявку	Своя	Нет	Нет	Нет
Читать карточки	Свои	Все	Нет	Нет
Редактировать тему	Своя NEW	Нет	Нет	Нет
Сменить статус	Авторские переходы	Рабочие переходы	Нет	Нет
Комментарии и вложения	Свои	Все	Нет	Нет
Управлять пользователями	Нет	Нет	Да	Нет
Читать аудит	Нет	Нет	Нет	Да

Создание учетной записи

Руководитель подразделения направляет заявку с именем, уникальным login, служебной почтой, ролью и сроком действия. Администратор проверяет основание, создаёт запись и передаёт временный пароль отдельным каналом.

Основание: заявка руководителя с именем сотрудника, служебным адресом, одной требуемой ролью, датой начала и окончания доступа и обоснованием. Администратор проверяет согласование, уникальность логина и отсутствие дубликата. Временный пароль передаётся защищённым каналом отдельно от логина; при первичном входе требуется смена по проектной процедуре, реализация которой должна быть предъявлена вместе с поставкой. В документации публичный API смены пароля не придумывается. Результат проверяется входом и разрешённым действием; реквизиты секрета в журнал не заносятся.

Изменение роли и атрибутов

Изменение роли выполняется по зарегистрированному согласованию; старые сеансы немедленно отзываются. Событие ROLE_CHANGED содержит старую и новую роль, субъекта и основание.

Новая роль назначается после подтверждения руководителя; прежняя не сохраняется второй ролью в той же записи. Проверяется, что следующий запрос применяет новые полномочия; при уменьшении прав действующие сеансы отзываются либо повторно проверяются сервером без окна сохранения прежних прав. Открытые заявки Оператора передаются другому ответственному согласованной административной процедурой с аудитом, а не редактированием таблиц без следа.

Блокирование и разблокирование

При увольнении доступ блокируется к моменту прекращения полномочий; при подозрении на компрометацию – немедленно после получения сообщения. Разблокирование выполняется после подтверждения личности и устранения причины.

До завершения операции проверить отзыв сеансов и сервисных токенов и выполнить контрольный запрос старым сеансом – ожидается 401. Временная автоматическая блокировка входа и административная блокировка доступа различаются:

истечение 15 мин не снимает административный blocked. Разблокирование не восстанавливает скомпрометированные токены; новые реквизиты выдаются после подтверждения основания.

Удаление и архивирование

Учётная запись переводится в архив без удаления ссылок из заявок и аудита. Персональные атрибуты обезличиваются после истечения согласованного срока хранения; открытые заявки предварительно передаются ответственному.

Требования к аутентификации

Пароль содержит не менее 12 символов и хранится как Argon2id-хеш с солью. После 5 ошибок за 15 мин вход блокируется на 15 мин. Непрозрачный сеанс передаётся браузером в cookie Secure, HttpOnly, SameSite = Strict; простой – 30 мин, абсолютный срок – 8 ч. Для изменяющих запросов браузера проверяется X-CSRF-Token; POST /auth/logout аннулирует сеанс. Интеграции используют отдельные сервисные записи и Bearer-токены со сроком 1 ч; токены в журналах не сохраняются.

Периодический пересмотр прав

Ежеквартально руководитель подтверждает список пользователей и роли; неподтверждённые записи блокируются, результат сохраняется в журнале согласований.

Запись согласования	Содержание
Основание	Номер заявки; руководитель; работник; причина выдачи или изменения
Объём	Логин; одна роль; дата начала/окончания; дополнительные отдельные записи
Выполнение	Администратор; время UTC; результат; событие аудита; проверка отзыва сеансов
Пересмотр	Период; решение руководителя; подтверждённые и неподтверждённые записи; дата блокировки

Привилегированные действия

Привилегированные операции: назначение роли, блокировка, изменение справочника, конфигурации, запуск восстановления и обновления. Нужны именная запись, основание и событие аудита.

Аудит событий доступа

События LOGIN_SUCCESS, LOGIN_FAILED, ACCOUNT_LOCKED, ROLE_CHANGED, SESSION_REVOKED фиксируются с UTC, actor_id, result и trace_id. Пароль и токен в аудит не включаются.

Действия при компрометации учетной записи

Немедленно заблокировать запись, отозвать все сеансы и токены, сохранить аудит, сменить секреты, определить затронутые объекты. Возобновить доступ только по решению ответственного за безопасность.

Сообщение фиксируется с временем и заявителем. Ответственный за безопасность определяет затронутые записи и согласует восстановление доступа; Администратор блокирует их и отзывает секреты. Аудит копируется в защищённое место с контролем целостности. При разборе устанавливаются период, выполненные операции, затронутые заявки и требуемые меры. Закрытие требует подтверждения смены реквизитов, проверки запрета старых сеансов и решения ответственного. Пароли и токены не включаются в материалы инцидента.

Лист регистрации изменений

Изм.	Номера листов (страниц)				Всего листов (страниц) в документе	Номер документа	Входящий номер сопроводительного документа и дата	Подпись	Дата
	изме-ненных	заме-ненных	новых	аннули-рованных					